



Incident Investigation scenario 1



Report Date: July 4, 2026

1. Executive Summary

This report documents the security investigation conducted regarding suspicious activities detected between July 2nd and July 3rd, 2026. The investigation focused on multiple automated authentication attempts originating from internal network assets.

Key Findings:

- **Detected Activity:** The monitoring systems identified automated scanning (Nmap) and repeated login attempts targeting the `/api/v1/employee/auth/login.php` endpoint.
- **Security Response:** Automated security controls, including the Web Application Firewall (WAF) and Intrusion Detection System (Suricata), successfully identified and blocked the malicious requests.
- **Account Integrity:** Although the attacker attempted to brute-force specific administrative accounts, including `nourhan.tamer`, all attempts were rejected.
- **Current Status: The system remains secure.** Our analysis confirms that there were no successful unauthorized logins, no data breaches, and no compromise of user accounts. The account lockout mechanism functioned correctly to prevent further unauthorized access.

Conclusion: The defensive layers of the infrastructure effectively mitigated the threat. No security incidents occurred, and the integrity of the system and user credentials remains intact.

2. Incident Identification Table

Category	Details
Incident day	2026-07-03
Severity	low or medium
Reasoning	Despite the intensive brute-force and reconnaissance attempts, the defense controls successfully blocked all unauthorized access; no data breach occurred.
Attacker IP	192.168.4.145 (Source of Attack)
Pivot/Intermediate IP	172.16.0.4
Target Resource	/api/v1/employee/auth/login.php
Attack Vector	Automated Scanning & Credential Stuffing/Brute-Force
Tools Used	Nmap Scripting Engine (NSE), Automated Custom Scripts
Data Sources	WAF Access Logs Suricata IDS Logs Windows Event Logs (4625, 4740) LDAP Logs
User Accounts Targeted	nourhan.tamer (and others within WebServer_Admins)
Detection Mechanism	Automated WAF/IDS alerts & SIEM log correlation
Incident Status	Mitigated / No Unauthorized Access

Impact Assessment	None (Confidentiality, Integrity, and Availability remained intact)
investigation tool	splunk

3. Timeline of Events

Time (2026-07-03)	Event Description	Source/Log Type	Outcome
06:54:00	Initial automated reconnaissance and enumeration phase.	Web Logs	High traffic detected.
07:02:00 - 07:04:00	Spike in request volume indicating an active brute-force attempt.	Web Logs	Automated tools detected.
07:04:05 - 07:08:45	Attacker probes for robots.txt to identify sensitive directories.	Web Logs	Successful file retrieval.
07:07:00 - 07:11:00	Aggressive authentication attempts (POST) on /api/v1/employee/auth/login.php.	Web/IDS Logs	Unauthorized (401/405 Errors).
07:10:00	Peak intensity of the brute-force attack (39 attempts in 1 min).	Web Logs	System remained stable.
07:10:31	Account	Windows Events	Account Blocked

nourhan.tamer
triggered a
lockout policy.

(4740).

07:11:01	Final recorded brute-force attempt detected	IDS Logs	401 Unauthorized Response.

4. Investigation Analysis

The WAF successfully blocked Nmap scanning attempts by returning a 403 Forbidden status.

Splunk Query :

index="depi-4" extracted_index=suricata "NSE" OR "nmap src_ip="192.168.4.125"

|table time src_ip dest_ip http_status http_method http_hostname

Analysis:

The screenshot shows that the WAF detected and blocked requests from the IP address 192.168.4.145 because they used the Nmap Scripting Engine. You can see the status code 403, which confirms that the WAF denied access to these requests.

_time	clientip	useragent	extracted_index	status	extracted_source	extracted_host	method	bytes
2026-07-03 06:57:06	192.168.4.145	Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)	waf_index	403	/var/log/apache2/waf-access.log	WAF	GET	2020
2026-07-03 06:57:05	192.168.4.145	Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)	waf_index	403	/var/log/apache2/waf-access.log	WAF	POST	2020
2026-07-03 06:57:05	192.168.4.145	Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)	waf_index	403	/var/log/apache2/waf-access.log	WAF	GET	2020
2026-07-02 22:57:05	192.168.4.145	Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)	waf_index	403	/var/log/apache2/waf-access.log	WAF	GET	2020

ملهم :

Alerts							
Alerts set a condition that triggers an action, such as sending an email that contains the results of the triggering search to a list of people. Click the name to view the alert. Open the alert in Search to refine the parameters.							
4 Alerts							
All Yours This App's filter							
i	Title	Actions	Owner	App	Sharing	Status	
>	AD Account Lockout Alert	Open in Search Edit	mosami	search	App	Enabled	
>	ManyRequests	Open in Search Edit	mosami	search	Private	Enabled	
>	NMAP_SCAN_Alert	Open in Search Edit	mosami	search	Private	Enabled	
>	WAF_Alert	Open in Search Edit	mosami	search	Private	Enabled	

اسكرينات الایمیلات

SECURITY OPERATIONS CENTER

Nmap Scan Blocked Automatically

SUCCESS

SOAR ACTION

Source IP was performing an Nmap scan and has been automatically blocked on FortiGate Firewall

RELEASED SOURCE IP

192.168.4.145

DESTINATION IP

172.16.0.3

ATTACK TYPE

Nmap Network Scan

ET SCAN: Possible Nmap Scan-Agents: Observed

DETECTION SUMMARY

Suricata detected 4 packets matching a known Nmap reconnaissance signature against 172.16.0.3. This activity is indicative of port scanning / network reconnaissance.

SECURITY DEVICE

FortiGate Firewall

AUTOMATED ACTION

Firewall Address Object Created

IP Added to Auto-Block Group

Traffic Blocked Successfully

EXECUTION STATUS

BLOCK SUCCESSFUL

Temporary block applied for 5 minutes. Traffic will be automatically re-evaluated after the block window expires.

Threat Intelligence Analysis

100%

HIGH RISK

LOOKUP IP

192.168.4.145

COUNTRY

DE

ISP

Arctic10 e.V.

USAGE TYPE

Commercial

TOR EXIT NODE

Nmap

TOTAL REPORTS

162

REPORTING

#1

LAST REPORTED

2025-07-02T10:00:24-00:00

Notes

Above score 100%, reported 162 times by 91 users, identified as a TOR Exit Node.

This response was generated automatically by the SOAR Incident Playbook and FortiGate Firewall. The response does not require manual intervention. The source IP was automatically blocked for 5 minutes.

SECURITY OPERATIONS CENTER

Automated Response Completed

COMPLETED

SOAR ACTION

Temporary firewall block related to an Nmap scan has expired and the IP address has been automatically removed.

RELEASED SOURCE IP

192.168.4.145

ORIGINAL BLOCK REASON

Nmap Network Scan Detected

SECURITY DEVICE

FortiGate Firewall

AUTOMATED ACTION

Address Object Removed

Removed from Auto-Block Group

Access Restored Automatically

BLOCK DURATION

5 Minutes

EXECUTION STATUS

BLOCK REMOVED SUCCESSFULLY

This response was generated automatically by the SOAR Incident Playbook and FortiGate Firewall. The response does not require manual intervention. The response was automatically removed after 5 minutes.

Suricata Analysis:

The Suricata logs further confirm that the internal security infrastructure successfully identified and blocked the attacker's reconnaissance attempts.

index="depi-4" extracted index=suricata "NSE" OR "nmap src_ip="192.168.4.125"

!table time src_ip dest_ip http_status http_method http_hostname

Analysis:

Suricata logged multiple blocked requests (Status 403) originating from 192.168.4.145. These logs provide cross-verification, proving that both the WAF and the network intrusion detection system flagged the activity as malicious "Nmap" scanning, ensuring the attacker's tools were effectively denied access.

_time	src_ip	dest_ip	http_status	http_method	http_hostname
2026-07-03 06:57:06.003	192.168.4.145	172.16.0.5	403	GET	192.168.4.128
2026-07-03 06:57:06.003	192.168.4.145	172.16.0.5	403	GET	192.168.4.128
2026-07-03 06:57:06.003	192.168.4.145	172.16.0.5	403	GET	192.168.4.128
2026-07-03 06:57:06.003	192.168.4.145	172.16.0.5	403	GET	192.168.4.128
2026-07-03 06:57:05.983	192.168.4.145	172.16.0.5	403	GET	192.168.4.128
2026-07-03 06:57:05.983	192.168.4.145	172.16.0.5	403	GET	192.168.4.128
2026-07-03 06:57:05.982	192.168.4.145	172.16.0.5	403	POST	192.168.4.128
2026-07-03 06:57:05.982	192.168.4.145	172.16.0.5	403	POST	192.168.4.128
2026-07-03 06:57:05.982	192.168.4.145	172.16.0.5	403	POST	192.168.4.128

Analysis of Automated Attack Patterns

```
index="depi-4" clientip="192.168.4.145" OR src_ip="192.168.4.145"
|bin _time span=2m
|stats count by _time
|where count >100
|sort - count
```

Analysis: The screenshot displays a count of requests grouped into two-minute intervals. The red-highlighted entries show thousands of requests (e.g., 2,583 requests within two minutes), which is clear evidence of an automated brute-force or scanning tool running against the target infrastructure.

_time	count
2026-07-03 07:02:00	2583
2026-07-03 07:04:00	2583
2026-07-03 04:06:00	726
2026-07-03 03:56:00	646
2026-07-03 04:02:00	638
2026-07-03 04:00:00	510
2026-07-03 04:04:00	499
2026-07-03 03:54:00	446
2026-07-03 07:10:00	139

Reconnaissance and Directory Enumeration

The attacker performed systematic directory enumeration to discover hidden files and sensitive endpoints on the server.

```
index="depi-4" clientip="192.168.4.145" OR src_ip="192.168.4.145"
|stats count by uri , status
|sort -count
```

Analysis:

The screenshot shows the attacker accessed robots.txt and various hidden files

uri	status	count
/api/v1/employee/auth/login.php	401	43
/	200	13
/login.php	200	9
/api/v1/company/staff-directory.php	200	8
/our-team.php	200	3
/api/v1/files/	200	2
/api/v1/files/upload.php	400	2
/robots.txt	200	2
/.htaccess	404	1
/.bash_history	403	1
/.bashrc	403	1
/.cache	404	1
/.config	403	1
/.cvs	404	1
/.cvsignore	404	1

The attacker specifically requested robots.txt to identify potentially restricted or sensitive site structures, a common precursor to targeted attacks.

clientip	file	method	referer	_time	uri	useragent
----------	------	--------	---------	-------	-----	-----------

The screenshot shows the attacker successfully retrieving the robots.txt file twice using different User-Agents (Firefox and Chrome). By obtaining this file, the attacker mapped out areas of the website that were meant to be hidden, allowing them to refine their attack strategy against specific backend endpoints.

clientip ↕	file ↕	method ↕	referer ↕	_time ↕	uri ↕	useragent ↕
192.168.4.145	robots.txt	GET	-	2026-07-03 07:08:45	/ robots.txt	Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
192.168.4.145	robots.txt	GET	-	2026-07-03 07:04:05	/ robots.txt	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/87.0.4280.88 Safari/537.36

ملحوظه : ان ال ip هئا متعملوش ای block

Sustained Brute-Force Authentication Attempt

```
index="depi-4" clientip="192.168.4.145"  
uri="/api/v1/employee/auth/login.php"
```

```
|table clientip uri useragent method _time
```

Analysis:

The screenshot captures a series of repetitive POST requests targeted at the login endpoint. The timestamps indicate a high-frequency attack, with attempts occurring every few seconds consistently up until 07:11, confirming a targeted brute-force campaign against the authentication service.

clientip	uri	useragent	method	_time
192.168.4.145	/api/v1/employee/auth/login.php	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.6167.85 Safari/537.36	POST	2026-07-03 07:10:01
192.168.4.145	/api/v1/employee/auth/login.php	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.6167.85 Safari/537.36	POST	2026-07-03 07:10:53
192.168.4.145	/api/v1/employee/auth/login.php	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.6167.85 Safari/537.36	POST	2026-07-03 07:10:57
192.168.4.145	/api/v1/employee/auth/login.php	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.6167.85 Safari/537.36	POST	2026-07-03 07:10:54
192.168.4.145	/api/v1/employee/auth/login.php	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.6167.85 Safari/537.36	POST	2026-07-03 07:10:53
192.168.4.145	/api/v1/employee/auth/login.php	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.6167.85 Safari/537.36	POST	2026-07-03 07:10:51
192.168.4.145	/api/v1/employee/auth/login.php	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.6167.85 Safari/537.36	POST	2026-07-03 07:10:58
192.168.4.145	/api/v1/employee/auth/login.php	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.6167.85 Safari/537.36	POST	2026-07-03 07:10:48
192.168.4.145	/api/v1/employee/auth/login.php	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.6167.85 Safari/537.36	POST	2026-07-03 07:10:47
192.168.4.145	/api/v1/employee/auth/login.php	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.6167.85 Safari/537.36	POST	2026-07-03 07:10:46
192.168.4.145	/api/v1/employee/auth/login.php	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.6167.85 Safari/537.36	POST	2026-07-03 07:10:45
192.168.4.145	/api/v1/employee/auth/login.php	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.6167.85 Safari/537.36	POST	2026-07-03 07:10:43
192.168.4.145	/api/v1/employee/auth/login.php	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.6167.85 Safari/537.36	POST	2026-07-03 07:10:42
192.168.4.145	/api/v1/employee/auth/login.php	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.6167.85 Safari/537.36	POST	2026-07-03 07:10:41
192.168.4.145	/api/v1/employee/auth/login.php	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.6167.85 Safari/537.36	POST	2026-07-03 07:10:40
192.168.4.145	/api/v1/employee/auth/login.php	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.6167.85 Safari/537.36	POST	2026-07-03 07:10:39
192.168.4.145	/api/v1/employee/auth/login.php	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.6167.85 Safari/537.36	POST	2026-07-03 07:10:38
192.168.4.145	/api/v1/employee/auth/login.php	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.6167.85 Safari/537.36	POST	2026-07-03 07:10:37
192.168.4.145	/api/v1/employee/auth/login.php	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.6167.85 Safari/537.36	POST	2026-07-03 07:10:36
192.168.4.145	/api/v1/employee/auth/login.php	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.6167.85 Safari/537.36	POST	2026-07-03 07:10:35
192.168.4.145	/api/v1/employee/auth/login.php	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.6167.85 Safari/537.36	POST	2026-07-03 07:10:34

Attack Result Analysis (Unauthorized Access Denied)

```
index="depi-4" clientip="192.168.4.145"  
uri="/api/v1/employee/auth/login.php"
```

```
|table clientip uri useragent method status _time
```

```
|dedup status
```

Analysis:

The screenshot shows that the attacker only received 401 Unauthorized (authentication failure) and 405 Method Not Allowed responses. This proves that the system's security controls were functioning correctly, as the attacker

failed to bypass the authentication layer or exploit the login method.

clientip	url	useragent	method	status	_time
192.168.4.145	/api/v1/employee/auth/login.php	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.6167.85 Safari/537.36	POST	401	2026-07-03 07:11:01
192.168.4.145	/api/v1/employee/auth/login.php	Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0	GET	405	2026-07-03 07:07:00

IDS Verification (Suricata Analysis)

```
index="depi-4" src_ip="192.168.4.145" http_url="*/login.php"
http_http_method=post

|table _time src_ip dest_ip http_url http_http_method
http_http_user_agent http_status extracted_index

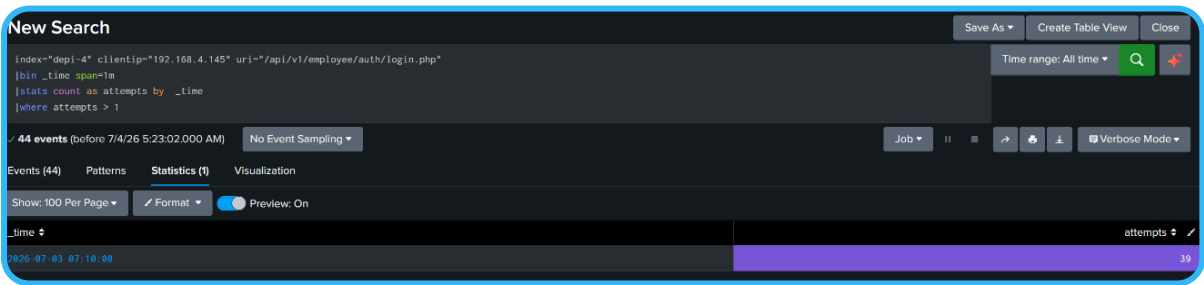
|dedup http_status
```

_time	src_ip	dest_ip	http_url	http_http_method	http_http_user_agent	http_status	extracted_index
2026-07-03 07:11:01.245	192.168.4.145	172.16.0.5	/api/v1/employee/auth/login.php	POST	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.6167.85 Safari/537.36	401	suricata

Analysis:.

The log entry confirms that the Suricata system correctly observed the 401 Unauthorized responses. This acts as a third layer of validation, ensuring that both the WAF and the IDS were fully aware of the brute-force attempts targeting the authentication endpoint.

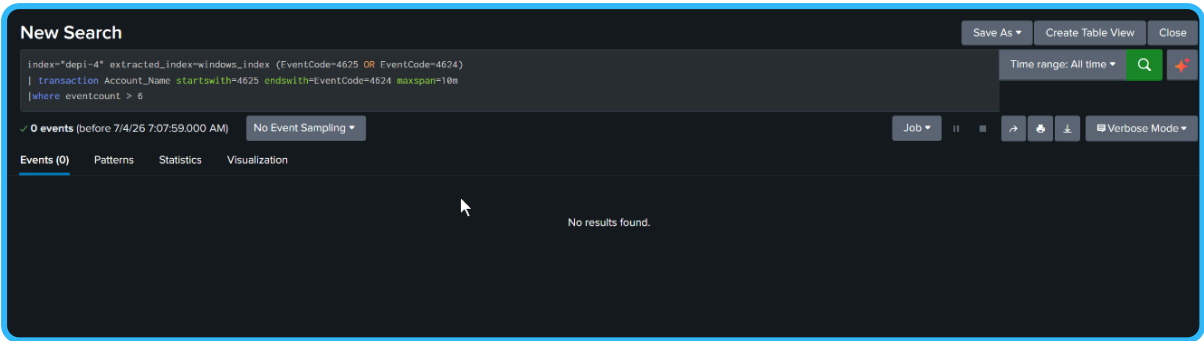
Peak Attack Intensity



Analysis:

The screenshot highlights a spike of 39 authentication attempts within a single minute (at 07:10:00). This confirms the aggressive nature of the brute-force campaign, showing that the attacker attempted to overwhelm the login endpoint in a concentrated burst.

Brute-Force unSuccess Verification:



Analysis: The query returned "No results found." This provides definitive proof that while the attacker launched multiple brute-force attempts (EventCode 4625), there was no corresponding successful login (EventCode 4624) for these accounts within the specified timeframe. This confirms that the attacker failed to gain unauthorized access to any user account.

Account Lockout Verification

```
index="depi-4" extracted_index=windows_index EventCode=4740
|table _time EventCode Message extracted_index ComputerName
Account_Name Account_Domain
```

Analysis:

The log entry shows an EventCode 4740, which explicitly states, "A user account was locked out." This confirms that the organization's security policy successfully triggered an account lockout for nourhan.tamer due to the malicious activity, preventing any further unauthorized attempts by the attacker.

_time	EventCode	Message	extracted_index	ComputerName	Account_Name	Account_Domain
2020-07-03 07:10:31.981	4740	A user account was locked out. Subject: Security ID: S-1-5-18 Account Name: DC\$ Account Domain: COMPANY Logon ID: 8x3E7 Account That Was Locked Out: Security ID: S-1-5-21-1680238161-1929983985-812562381-1113 Account Name: nourhan.tamer Additional Information: Caller Computer Name: DC	windows_index	DC.company.local	DC\$ nourhan.tamer	COMPANY

Internal LDAP Enumeration and User Profiling

```
index="depi-4" "nourhan.tamer" event_type=ldap

|table src_ip dest_ip ldap_responses___search_result_entry_base_object
ldap_responses___search_result_entry_attributes___values
ldap_responses___bind_response_result_code
ldap_request_search_request_base_object
```

Analysis:

The screenshot confirms that the IP 172.16.0.4 acted as a pivot point to perform LDAP queries against the target. It successfully retrieved details for the user nourhan.tamer (part of the WebServer_Admns OU). However, the subsequent authentication attempts were flagged as `invalid_credentials`, proving the attacker had access to directory information but failed to authenticate with valid passwords.

172.16.0.4	172.16.1.4		invalid_credentials	
172.16.0.4	172.16.1.4		invalid_credentials	
172.16.0.4	172.16.1.4		invalid_credentials	
172.16.0.4	172.16.1.4		invalid_credentials	
172.16.0.4	172.16.1.4		invalid_credentials	
172.16.0.4	172.16.1.4		invalid_credentials	
172.16.0.4	172.16.1.4	CN=Mohamed,OU=WebServer_Admns,OU=HQ,DC=company,DC=local CN=Nourhan Tamer,OU=WebServer_Admns,OU=HQ,DC=company,DC=local CN=Roaa Ayman,OU=WebServer_Admns,OU=HQ,DC=company,DC=local CN=Islam Habbrouk,OU=WebServer_Admns,OU=HQ,DC=company,DC=local CN=Abdelrahman Mosaad,OU=WebServer_Admns,OU=HQ,DC=company,DC=local CN=Islam Ahmed,OU=WebServer_Admns,OU=HQ,DC=company,DC=local	Network Security Engineer Mohamed Sami Information Security mohamed.sami@company.local Penetration Tester Nourhan Tamer Cybersecurity Team nourhan.tamer@company.local Penetration Tester Roaa Ayman Cybersecurity Team roaa.ayman@company.local Security Automation Engineer Hamed Habbrouk SOC Team hamed.habbrouk@company.local SOC Analyst Abdelrahman Mosaad SOC Team abdelrahman.mosaad@company.local SOC Analyst Islam Ahmed SOC Team islam.ahmed@company.local	OU=WebServer_Admns,OU=HQ,DC=company,DC=local

اسكرين correlation

اسكرين virus total

اسكرين email

always===== اسكرين block ip in FGT

5. Indicators of Compromise (IoCs)

Type	Indicator	Description
Attacker IP	192.168.4.145	The primary source IP for the brute-force attempts.

Intermediate IP	172.16.0.4	An internal device used as a pivot point for relaying attacks and LDAP requests.
Target URL	/api/v1/employee/auth/login.php	The target endpoint for the forced login attempts.
User-Agent	Mozilla/5.0 ... Firefox/115.0	One of the browsers used in the attack (detected during the robots.txt request).
User-Agent	Mozilla/5.0 ... Chrome/121.0.6167.85	The browser used during the intensive brute-force campaign.
Targeted Account	nourhan.tamer	The account directly targeted, which subsequently triggered a lockout.
Malicious File	robots.txt	The file accessed during the reconnaissance phase.

6.Actionable Security Recommendations

1. Blacklist Configuration & Traffic Filtering

- IP Blocking: Update the Web Application Firewall (WAF) and Perimeter Firewall rules to permanently drop all traffic originating from 192.168.4.145.
- Rate Limiting: Configure the WAF to implement a "sliding window" rate limit on the /api/v1/employee/auth/login.php endpoint. For example, block any source IP that exceeds 5 failed attempts within a 60-second window.

2. Credential Management & Hardening

- Forced Reset: Initiate a mandatory password rotation for the nourhan.tamer account and any other accounts identified in the LDAP enumeration.

- MFA Integration: Mandatory implementation of Multi-Factor Authentication (MFA) for the WebServer_Admis group. This ensures that even if a password is guessed via brute-force, the account remains inaccessible.
- Account Policy Review: Shorten the account lockout duration and enable automatic alerting for security administrators when EventCode 4740 is triggered.

3. Sensitive File Protection (robots.txt)

- Access Restriction: Update the web server configuration (e.g., Nginx or Apache) to deny access to robots.txt and other sensitive configuration files from unauthorized network subnets.
- Content Sanitization: Ensure robots.txt does not leak internal directory structures or administrative endpoints to external crawlers.
- Monitoring Access: Configure the web server to log and alert whenever there is a 403 or 404 access attempt on sensitive files, as this is a primary indicator of automated reconnaissance.

4. SIEM Alerting (EventCodes)

- Threshold-Based Alerts: Configure your SIEM (Splunk) to trigger a "High Severity" alert when the sum of EventCode 4625 (Failed Login) for a single user exceeds 5 attempts within 10 minutes.
- Correlation Rule: Create a correlation rule to alert when EventCode 4625 is followed by EventCode 4740 (Account Lockout) for the same user within a short timeframe.
- Visualization: Build a real-time dashboard in your SIEM to monitor EventCode 4625 and 4740 across all domain controllers to detect lateral movement or widespread credential stuffing attacks.

5. Penetration Testing Toolset Suggestion

To act like a professional penetration tester and validate these defenses, you should use industry-standard tools to simulate these attacks in a controlled, authorized environment:

- For Brute-Force Testing: Use Hydra or Burp Suite Professional (Intruder) to test the strength of your login endpoints against credential stuffing.
- For Reconnaissance Simulation: Use Nmap (specifically the --script flags like http-enum or http-robots.txt) to identify how much information your web server leaks.
- For LDAP Enumeration: Use enum4linux or ldapsearch to verify if your LDAP directory is leaking sensitive user metadata as observed in your incident.

Recommendations Summary

Priority	Action	Responsibility
High	Blacklist Attacker IP 192.168.4.145	Network Team
High	Password reset for nourhan.tamer	IAM Team
Medium	Configure SIEM Alerts for 4625/4740	SOC Team
Medium	Implement Rate Limiting on /login.php	Web Dev/Security
Low	Restrict robots.txt access	SysAdmin

7.Impact Assessment

Impact Category	Status / Details
Confidentiality	None. No unauthorized access was gained to sensitive data or internal systems.
Integrity	None. The system's configuration and user data remain intact and unaltered.
Availability	Minimal. The target account nourhan.tamer was temporarily locked out as a security precaution, causing a minor disruption to that specific user only.
Overall Impact	Low. The security measures (WAF, IDS, and Account Lockout policies) successfully contained the threat before it escalated.

8.References

- network topology

9.Conclusion:

The incident has been fully investigated and mitigated. The security controls functioned as expected, preventing unauthorized access. This incident is marked as **Closed**. No further action is required beyond the recommended hardening steps.